

한국에너지공단 상임감사

현 지 조 치

제 목 정보보안 및 개인정보보호 관리 미흡

소 관 부 서 건물에너지실

조 치 부 서 건물에너지실

내 용

1. 업무개요

공단은 국가정보원 「국가 정보보안 기본지침」 및 개인정보보호위원회 「개인 정보보호법」에 따라 정보보안 및 개인정보보호 업무에 필요한 세부사항을 규정 하기 위해 「정보보안 세부지침」 및 「개인정보 보호 내부 관리계획」을 제정 · 운영하고 있다.

2. 관계법령 및 판단기준

「정보보안 세부지침」 제73조(단말기 보안)²⁷⁾에 따르면 개별 사용자는 공단

27) 제73조(단말기 보안) ①개별사용자는 공단에서 지급받은 PC·노트북·휴대폰 등 단말기(이하 “단말기”라 한다) 사용과 관련한 일체의 보안관리 책임을 진다.

②개별사용자는 단말기에 대하여 다음 각 호에 해당하는 보안대책을 준수하여야 한다.

1. CMOS·로그온·자료 암호화 비밀번호의 정기적 변경 사용
2. 단말기 작업을 10분 이상 중단시 비밀번호 등을 적용한 화면보호 조치
3. 최신 백신 소프트웨어 설치
4. 운영체제 및 응용프로그램에 대한 최신 보안패치 유지
5. 출처, 유통경로 및 제작자가 불분명한 응용프로그램의 사용 금지
6. 인터넷을 통해 자료(파일) 획득시 신뢰할 수 있는 인터넷사이트를 활용하고 자료(파일) 다운로드시 최신 백신 소프트웨어로 검사 후 활용
7. 인터넷 파일공유·메신저·대화방 프로그램 등 업무상 불필요한 프로그램의 설치 금지 및 공유 폴더 삭제
8. 웹브라우저를 통해 서명되지 않은 액티브-X 등이 다운로드·실행되지 않도록 보안 설정
9. 내부망과 인터넷망이 분리된 기관의 인터넷 PC에서는 특별한 사유가 없는 한 문서프로그램을 읽기 전용(專用)으로 운용
10. 그 밖에 국가정보원장이 안전성을 확인하여 배포한 프로그램의 운용 및 보안권고문 이행 (이하 생략)

에서 지급받은 PC, 노트북, 휴대폰 등(이하 “단말기”라 한다)의 사용과 관련하여 정기적인 비밀번호 변경, 최신 보안패치 유지, 불필요한 프로그램 설치 금지 등 일체의 보안관리 책임을 이행하여야 한다.

또한, 「개인정보보호법 시행령」 제30조(개인정보의 안전성 확보 조치)²⁸⁾, 「개인정보 보호 내부 관리계획」 제8조(개인정보취급자의 범위, 역할 및 책임)²⁹⁾에 따라 개인정보취급자는 정보주체의 개인정보를 보호하기 위해 필요한 조치에 대해 명확한 역할과 책임을 가진다.

3. 감사결과 확인된 문제점

이와 관련하여, IT 전문가 준감사인과의 협력감사를 통해 건물에너지실의 정보보안 및 개인정보보호 관리기준 준수 여부를 확인한 결과, 아래의 [표]와 같이 PC 내 개인정보 파일을 암호화하지 않은 사례와 CMOS 암호를 설정하지 않은 사례가 발견되어 현지에서 시정 조치하였다.

[표] 정보보안 관리기준 미준수 사례

연번	제 목	내 용	관련자
1	개인정보 암호화 미흡	업무용 PC 내 개인정보 포함 파일 미 암호화	N
2	CMOS 암호 미설정	업무용 단말기 CMOS 암호 미설정	O

28) 제30조(개인정보의 안전성 확보조치) ① 개인정보처리자는 법 제29조에 따라 다음 각 호의 안전성 확보 조치를 해야한다. (이하 생략)

29) 제8조(개인정보취급자의 범위, 역할 및 책임) ① 개인정보취급자의 범위는 공단 내에서 정보주체의 개인정보 수집, 보관, 처리, 이용, 제공, 관리 또는 파기 등의 업무를 수행하는 자를 말하고 내부직원 및 외부업체 직원을 의미한다.

② 개인정보취급자는 정보주체의 개인정보보호를 위해 다음의 역할 및 책임을 이행한다.

1. 개인정보보호 활동 참여
2. 내부 관리계획의 준수 및 이행
3. 개인정보의 안전성 확보조치 기준 이행
4. 개인정보파일의 등록 및 변경 신청
5. 개인정보의 파기
6. 기타 정보주체의 개인정보보호를 위해 필요한 사항의 이행